

REPORT U3_S11_L5

Oggetto dell'analisi: Esame del file [Jvczfhe.exe](#) in ambiente di sandbox automatizzata

Sistema Operativo di test: Windows 10 Professional (64-bit)

Esito Finale dell'Analisi: ● **Attività Maliziosa Confermata (Malicious Activity)**

1. Dati del Campione ed Elementi Identificativi (IoC)

In questa prima fase ho raccolto gli **Indicatori di Compromissione (IoC)** per identificare in modo univoco il file analizzato e tracciarne la provenienza:

Parametro	Dettaglio / Valore
Nome File Analizzato	Jvczfhe.exe
URL di Origine	[https://github.com/MELITERRER/frew/blob/main/Jvczfhe.exe] (https://github.com/MELITERRER/frew/blob/main/Jvczfhe.exe)
Hash MD5	00B5E91B42712471CDFBDB37B715670C
Hash SHA256	0307EE805DF8B94733598D5C3D62B28678EAEADBF1CA3689FA678A3780DD3DF0
Protezione Rilevata	.NET Reactor (Protector / Obfuscator)

2. Spiegazione delle Minacce e Tecniche Rilevate

Analizzando il report comportamentale di ANY.RUN, ho isolato **5 comportamenti chiave** usati dal malware per infettare il sistema e non farsi scoprire:

1. Offuscamento del Codice (.NET Reactor)

- **Cosa significa:** Il file è stato "impacchettato" e cifrato con **.NET Reactor**.
- **Perché viene usato:** Gli sviluppatori software lo usano per proteggere il proprio codice dal plagio, ma i cybercriminali lo sfruttano per **nascondere le istruzioni**

maliziose agli antivirus. L'antivirus non riesce a leggere il codice finché il programma non viene eseguito in memoria RAM.

2. Tecnica di Evasione dalla Sandbox (Anti-Analysis)

- **Cosa significa:** Il processo **Jvczfhe.exe** avvia il prompt dei comandi (**cmd.exe**) lanciando il comando **timeout 21**.
- **Perché viene usato:** Molte sandbox automatiche analizzano i programmi sospetti solo per un tempo limitato (spesso 15-30 secondi). Mettendo il sistema in pausa forzata per 21 secondi, il malware tenta di **far scadere il tempo di analisi** per poi attivarsi quando la sandbox pensa che il file sia inoffensivo.

3. Ricognizione del Sistema (System Fingerprinting)

- **Cosa significa:** Il programma legge varie chiavi di registro di Windows per estrarre:
 - Il nome del computer e l'ID univoco dell'installazione (**Machine GUID**).
 - La lingua di sistema e le impostazioni di sicurezza di Internet Explorer.
- **Perché viene usato:** Serve al malware per capire se si trova sul computer di una vera vittima o in una macchina virtuale d'analisi usata dai ricercatori. Se capisce di essere sotto controllo, può scegliere di bloccarsi.

4. Abuso di Strumenti di Sistema (Living off the Land)

- **Cosa significa:** Il malware genera un secondo file (**Muadnrd.exe**) e sfrutta il programma di Windows **InstallUtil.exe** (un'utilità ufficiale Microsoft del framework .NET).
- **Perché viene usato:** Questa tecnica consiste nell'usare programmi legittimi già presenti in Windows. I firewall e gli antivirus tendono a fidarsi dei file firmati da Microsoft come **InstallUtil.exe**, permettendo al malware di muoversi in rete senza far scattare allarmi.

5. Connessione di Comando e Controllo (C2) via Dynamic DNS

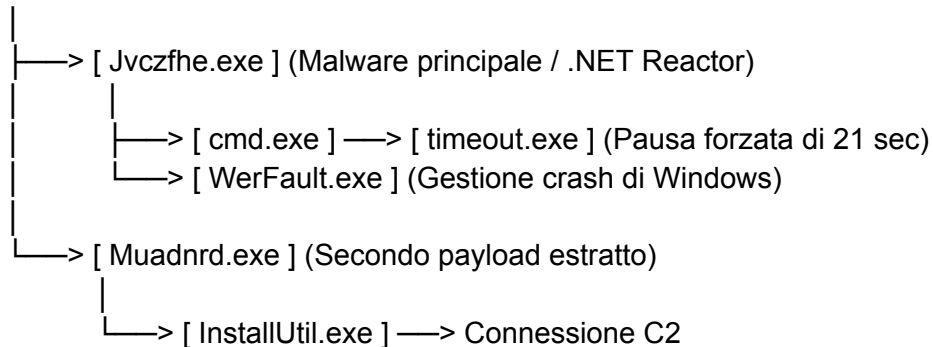
- **Cosa significa:** Il processo **InstallUtil.exe** apre una connessione verso l'esterno:
 - **Dominio:** **egehgdhjbhjtreduckdns.org**
 - **IP Destinazione:** **91.92.253.47**
 - **Porta:** **7702** (Porta insolita)
- **Perché viene usato:** **DuckDNS** è un servizio gratuito di DNS dinamico che permette ai malintenzionati di nascondere il proprio indirizzo IP reale. La **porta 7702** viene usata dai Trojan di controllo remoto (RAT) per inviare dati rubati o ricevere comandi dall'attaccante.

3. Schema dell'Esecuzione (Process Tree)

Ecco come i vari processi si sono attivati in sequenza durante l'analisi dinamica:

Plaintext

[firefox.exe] ---> Download del file da GitHub



(egehgdehjbhjtire.duckdns.org:7702)

4. Contromisure Consigliate

Per proteggere la rete da questo tipo di minaccia, le azioni immediate da intraprendere sono:

1. **Blocco Network:** Inserire nel firewall la regola di blocco verso la porta **7702** e verso i domini che utilizzano la risoluzione [*.duckdns.org](https://duckdns.org).
2. **Monitoraggio EDR:** Creare una regola di sicurezza per monitorare qualsiasi processo figlio generato da [InstallUtil.exe](#).
3. **Segnalazione:** Effettuare la segnalazione (takedown) del repository su GitHub per far rimuovere l'eseguibile dannoso.